

Enterprise Risk Report — Q1 2026

Prepared by Enterprise Risk Management · Classification: Confidential

1. Executive summary

Northstar Holdings operates a 5×5 likelihood-impact risk matrix. Residual risk is accepted only at Medium or below unless the Board grants a time-bound exception. The Chief Risk Officer is Dana Voss. This quarter the top residual exposure remains ransomware against core finance systems, rated High after compensating controls. Third-party vendor risk is Medium following dual-provider payroll cutover. No new Critical residual risks were accepted in Q1 2026.

2. Top residual risks

Risk	Owner	Inherent	Residual	Trend
Ransomware / destructive malware against core finance systems	CISO	Critical	High	Stable
Third-party SaaS outage affecting payroll and vendor payments	CRO	High	Medium	Improving
Regulatory reporting error under SOX and privacy statutes	GC	High	Medium	Stable
Key-person concentration in treasury operations	CFO	Medium	Medium	Worsening

3. Ransomware scenario

The ransomware residual risk rating is High. Inherent risk is Critical because a successful encryption event could halt close, payroll, and customer billing for more than 72 hours. Compensating controls include immutable backups tested monthly, network segmentation of finance servers, privileged access workstations, and a tabletop exercise completed in February 2026. Residual risk remains High because backup restore for the general ledger still exceeds the 8-hour recovery time objective. The treatment plan is to complete ledger restore automation by 30 June 2026, owned by the CISO with Finance Operations as the business sponsor.

4. Third-party and vendor risk

Third-party vendor residual risk is Medium. All vendors that process Confidential data require SOC 2 Type II or equivalent, annual security questionnaires, and a right-to-audit clause. Critical vendors are reviewed twice per year. A payroll provider outage in November 2025 delayed one cycle by 19 hours; a secondary provider is now contracted. Vendors without current SOC 2 reports are not permitted to receive Restricted data.

5. Risk appetite and reporting

Risk appetite statements: (a) zero tolerance for intentional regulatory breaches; (b) no more than two High residual technology risks without a Board-dated treatment plan; (c) recovery time for material financial systems must not exceed 8 hours after the treatment plan closes. KRIs reported monthly to the committee include phishing fail rate, privileged account count, open Critical audit findings, and backup restore success. This report is Confidential and is not for distribution outside the committee, executive team, Internal Audit, and Compliance.